

BRACE Sign-Off Checklist

A go / no-go gate for the engineer or manager who signs off on putting an autonomous AI agent into production.

How to use it. Work top to bottom. **Gate 1 is blocking:** if any Gate 1 item is not “yes,” do not ship. Gate 2 and Gate 3 items that are not met are **accepted residual risk** — record them, with who accepted them and why. Each item names the BRACE control it comes from and the question to answer before sign-off.

GATE 1 — Blocking: prevent damage, preserve attribution

Sign-off is withheld until every item is checked. These bound the worst documented incidents and guarantee you can reconstruct what happened.

- ☐ **Destructive-action interception (Control 4).** Is there an explicit list of destructive verbs — delete, DROP, force-push, infrastructure teardown, payment-state change, external send — that is **denied by default** and requires higher-tier authorization?
Covers: data destruction (Replit, Gemini-CLI incidents); OWASP ASI02 Tool Misuse
- ☐ **Capability-scoped credentials (Control 2).** Does the agent’s token carry only the capabilities it needs (read: tickets, not *), with no standing access to systems outside its task?
Covers: privilege escalation, lateral movement, credential access
- ☐ **Tested kill switch (Control 8).** Can you halt the agent **and all its sub-agents** within a time budget matched to the risk, and was that actually tested recently?
Covers: loss of control, rogue deployment, cascading failure
- ☐ **Audit trail (Control 9).** Is every action logged as the full execution graph, not just the final output, enough to do root-cause and attribution?
Covers: the recovery surface for every threat; resistance to evidence tampering
- ☐ **Six required identity fields (T1).** Does every action emit all six — accountable party, operational owner, tenant, agent-type-id, agent-instance-id, trace context — with the agent-type-id computed as a content hash over container, harness, system prompt, model, and config?
Covers: identity abuse, inter-agent attribution, detecting a silently changed config
- ☐ **Agent identity separate from the launching user (T1).** Does the agent have its own identity instead of inheriting the user’s, so its access can be scoped and revoked on its own?
Covers: a hijacked agent inheriting a human’s broad permissions; OWASP ASI03

GATE 2 — Required or documented: harden the substrate

Each item not met is recorded as accepted risk, with the threats it leaves exposed.

- ☐ **Environment isolation (Control 1).** Is the agent’s environment routed only to what its task needs — no path to the production admin plane, no live internet for an internal-only agent?
- ☐ **Signed, minimal, isolated container (Control 3).** Is the image signed (hash in the type-id), stripped of anything it doesn’t need, and run on a kernel-isolated runtime?
- ☐ **Input validation at the boundary (Control 5).** Is all external data treated as untrusted and validated at the boundary, with untrusted data kept on a separate channel from instructions?
- ☐ **Context-size logging (T2).** Is the context size logged per action, so failures that only appear at large context sizes are visible?
- ☐ **Egress allowlist (Control 1).** Is outbound traffic restricted to an allowlist, with anything else blocked and alerted?

GATE 3 — Active detection: catch what prevention misses

Required for high-stakes or high-autonomy deployments. For lower-stakes ones, deferral is recorded as accepted risk.

- ☐ **Behavioral security monitoring (Control 7).** Is there a security-anomaly baseline, separate from quality monitoring — at minimum simple rules (encoded payloads, non-allowlisted egress, out-of-path writes)?
- ☐ **Memory provenance and scoping (Control 6).** Is memory scoped per instance and per type, with no cross-type read without explicit gating, writes validated, and per-entry provenance queryable?
- ☐ **Sub-agent and parent-prompt provenance (T3).** When the agent spawns sub-agents, are the parent-child link and the prompt the parent gave captured as audit data?
- ☐ **Misaligned-intent signal (Control 7).** If deliberate misalignment is in scope, does second-model or sequence-pattern review carry at least a coarse intent-anomaly signal?

Sign-off record. Record the deployment name and **agent-type-id**; the date and approver; confirmation that **Gate 1 is complete**; each Gate 2 / Gate 3 item deferred, with the reason and the threats it leaves open; and the next scheduled re-review. **Re-mint the agent-type-id and re-run this checklist** on any change to the container, harness, system prompt, model, or capability set.